

Final Report

External Penetration Testing Assessment Report

Prepared For:

PosBuzz Retail Solutions

Prepared By: AMIR HAMZA

Name: Amir Hamza

Student ID: 2023200000660

Serial Number: 11

Course:

Applied Penetration Testing Engineer

Submission Date: 18 May 2026

Section 1 — Executive Summary

This report summarizes findings from three security exercises covering Active Reconnaissance, OWASP Juice Shop, and the Blue (MS17-010) vulnerable machine. The assessments demonstrate how misconfigurations, insecure coding practices, and unpatched systems can lead to severe security risks. Across all environments, attackers could gain information disclosure, bypass authentication, and achieve full system compromise. The findings highlight the importance of secure configuration, patch management, and secure coding practices.

Section 2 — Scope of Assessment

In Scope:

- TryHackMe Active Reconnaissance Room
- OWASP Juice Shop Vulnerable Web Application
- Blue (MS17-010 / EternalBlue) Windows Machine

Out of Scope:

- Real production systems
- External third-party infrastructure
- Denial of Service (DoS) testing

Section 3 — Methodology

The assessment followed a structured penetration testing methodology:

1. Reconnaissance — Identifying live hosts and gathering initial information.
2. Vulnerability Analysis — Identifying potential weaknesses in applications and services.
3. Exploitation — Attempting controlled exploitation of discovered vulnerabilities.
4. Post-Exploitation — Privilege escalation and data extraction.
5. Reporting — Documenting findings, impact, and remediation strategies.

Section 4 — Active Reconnaissance Summary

Tools used: ping, traceroute, telnet, netcat, browser DevTools.

Findings:

- Information disclosure via headers, SSL data, and JavaScript files
- ICMP responses revealed host availability and OS hints
- Network paths exposed internal routing structure
- Banner grabbing revealed service versions

Impact:

- Early exposure of system details aids attackers in targeting vulnerabilities
- Network mapping increases attack precision

Remediation:

- Disable unnecessary banners and metadata exposure
- Restrict ICMP and traceroute responses
- Replace insecure protocols like Telnet with SSH

Section 5 — OWASP Juice Shop Summary

Findings:

- Information disclosure through application features
- Broken authentication allowing login bypass
- SQL Injection vulnerabilities in login forms

Impact:

- Unauthorized access to accounts
- Data exposure and potential data theft
- Privilege escalation to admin level

Remediation:

- Use parameterized queries
- Validate and sanitize all inputs
- Implement secure authentication mechanisms

Section 6 — Blue Room Summary

Vulnerability: MS17-010 (EternalBlue SMB Exploit)

Findings:

- Exposed SMB service on port 445
- Remote code execution via EternalBlue exploit
- SYSTEM-level privilege escalation achieved
- Credential hashes dumped and cracked

Impact:

- Full system compromise
- Credential theft enabling lateral movement
- Sensitive system file access

Remediation:

- Apply MS17-010 patch
- Disable SMBv1

- Restrict port 445 access
- Enable credential protection features

Section 7 — General Remediation Recommendations

- Keep systems and applications fully patched
- Use secure coding practices (input validation, parameterized queries)
- Disable legacy and insecure protocols
- Implement continuous monitoring and logging
- Conduct regular vulnerability assessments

Section 8 — Conclusion

The assessments demonstrate how common vulnerabilities across web applications, network services, and outdated systems can lead to severe compromise. Proper security hygiene, secure development practices, and timely patch management are essential to mitigate these risks.